



ARKA HEALTH, INC.

ENCRYPTION & KEY MANAGEMENT POLICY

Cryptographic protection of ePHI at rest and in transit — 45 C.F.R. §§ 164.312(a)(2)(iv), 164.312(e)(2)(ii)

ARKA-SEC-004 · Version 1.0 · Confidential — Internal

Document No.	ARKA-SEC-004
Version	1.0
Effective Date	June 10, 2026
Last Reviewed	June 10, 2026
Document Owner	Arri Kanna, Founder & Chief Executive Officer — Privacy & Security Officer
Approved By	Arri Kanna, Founder & Chief Executive Officer
Classification	Confidential — Internal
Review Cycle	Annual, and upon any material change in operations, systems, or law

This document contains confidential and proprietary information of ARKA Health, Inc. (“ARKA”). It is furnished for informational and compliance purposes, may not be reproduced or disclosed to any third party without the prior written consent of ARKA, and must be returned or destroyed upon request. Nothing in this document constitutes legal advice.

1. POLICY STATEMENT

ARKA Health, Inc. encrypts all electronic Protected Health Information, and all Company confidential information, at rest and in transit, without exception and without reliance on the historical “addressable” designation of the encryption implementation specifications. Unencrypted ePHI shall not exist on any ARKA system, medium, or transmission path. Encryption rendering ePHI unusable, unreadable, or indecipherable to unauthorized persons shall conform to the standards referenced in the HHS Guidance issued under section 13402(h)(2) of the HITECH Act, such that properly encrypted data qualifies as “secured” for purposes of the Breach Notification Rule.

2. APPROVED ALGORITHMS AND PROTOCOLS

Context	Standard	Prohibited
Data at rest (databases, object storage, backups, snapshots)	AES-256 (GCM or XTS as platform-appropriate); FIPS 140-2/140-3 validated modules where available	DES, 3DES, RC4, ECB mode in any cipher
Data in transit (external)	TLS 1.2 minimum, TLS 1.3 preferred; HSTS with one-year max-age on all public endpoints; certificates from publicly trusted CAs, auto-renewed	TLS $\leq$ 1.1, SSL, plaintext HTTP, opportunistic-only SMTP for messages containing ePHI
Data in transit (internal / service-to-service)	TLS 1.2+ or provider-managed encrypted transport between availability zones	Unencrypted service meshes carrying ePHI
Password storage	Salted adaptive hashing (bcrypt, scrypt, or Argon2id)	MD5, SHA-1/SHA-256 without salt and stretching
Endpoint storage	Full-disk encryption (FileVault / BitLocker) enforced on all Workforce endpoints	Unencrypted laptops or removable media (removable media prohibited generally — ARKA-SEC-012)

3. KEY MANAGEMENT

- Generation and storage.** Cryptographic keys are generated and held in the managed key-management services of ARKA’s cloud providers (e.g., AWS KMS and the managed encryption layers of Vercel and Supabase); private keys shall not be exported, committed to source control, or stored on endpoints.
- Separation.** Key-administration privileges are separated from data-access privileges; no single role may both administer keys and hold unrestricted data access, except the break-glass identity described in ARKA-SEC-003, § 3(e).
- Rotation.** Provider-managed keys rotate per provider standard (at least annually); ARKA-managed application secrets rotate per ARKA-SEC-003, § 3(d). Compromise of any key requires immediate revocation, re-encryption assessment, and incident handling under ARKA-SEC-006.
- Backup keys.** Keys protecting backups are distinct from production data keys, so that compromise of one tier does not expose the other.
- Documentation.** The Security Officer maintains a key inventory (purpose, custodian, rotation date, validation status) reviewed at each annual risk analysis.

4. EXCEPTIONS

Because encryption is a non-waivable baseline of the Company, exceptions to this Policy are not available under the general exception process of ARKA-GOV-001. A transmission requested by a Customer over an unencrypted channel shall be declined and the requirement of this Policy communicated to the Customer in writing.

DOCUMENT CONTROL & REVISION HISTORY

Version	Date	Author / Reviewer	Description of Change
0.9	May 22, 2026	A. Kanna (drafting); external review pending	Initial draft circulated for internal review and counsel comment.
1.0	June 10, 2026	A. Kanna, Privacy & Security Officer	Adopted as effective policy of ARKA Health, Inc. by written approval of the undersigned officer.

ADOPTION AND APPROVAL

The undersigned, being the duly designated Privacy Officer and Security Officer of ARKA Health, Inc., hereby adopts this document as an official policy of the Company, effective as of the Effective Date set forth on the cover page hereof. This document shall be reviewed no less frequently than annually and upon any material change to the Company's operations, information systems, or applicable law, and may be amended only in accordance with ARKA-GOV-001 (Information Security & Compliance Program Charter).

ARKA HEALTH, INC.

By: _____

Name: Arri Kanna

Title: Founder & Chief Executive Officer; Privacy & Security Officer

Date: June 10, 2026